PDPL Compliance

How PhysioGuidance meets Saudi Personal Data Protection Law requirements — user rights, consent management, retention automation, evidence trail, and the full controls matrix as of handover.

PREPARED FOR

PhysioGuidance Client Team

DATE

2026-08-17

PDPL ARTICLES COVERED

4, 6, 11, 12, 13, 18, 25, 26, 27, 29

PHYSIOGUIDANCE

Riyadh · Saudi Arabia
me-central2 · GCP Cloud Run

Table of contents

1. Executive summary
2. Scope — what personal data the platform handles
3. Data flow for a user right request
4. User rights — implementation-by-article
5. Consent management (marketing + sensitive data)
6. Retention and purge automation
7. Inactive-user handling
8. Audit trail for privacy-related requests
9. PII encryption at rest
10. Data residency (Article 29)
11. Controls matrix — every control classified
12. Related deliverables
13. Where to look next

1. Executive summary

Every user-rights capability required by PDPL is live in the deployed backend (commit `d396b040`) and exercised via user-facing UI + admin APIs. Retention and inactive-user handling are automated by a single daily job inside the worker service. PII is encrypted at rest with AES-256-GCM. Every privacy-related state change writes a row to `audit_logs`. All data lives in me-central2 (Dammam) per Article 29.

The full per-control matrix is delivered separately as pdpl-controls-matrix.csv. This document explains the architecture behind those controls and shows the end-to-end flows a data subject or auditor will follow.

2. Scope — what personal data the platform handles

The full field-by-field classification is in pdpl-data-classification.csv. Summary:

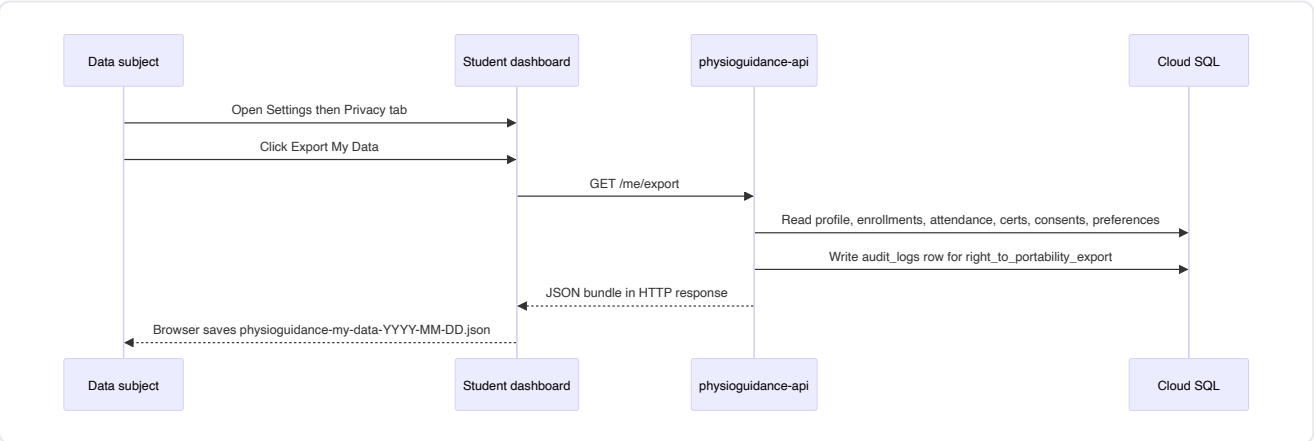
Category	Examples	Sensitivity
Identity	first name, last name, email, phone, National ID / Iqama	Personal Data
Professional	SCFHS registration number, professional bio	Personal Data
Learning	course enrollments, attendance records, assessment scores, certificates	Personal Data
Financial	payment records, refund details, bank IBAN (for refunds only)	Sensitive Personal Data — encrypted
Health-adjacent	none collected today	Not Applicable
Behavioral	audit logs of user actions, login history	Personal Data
Authentication	password hash (argon2), refresh tokens, 2FA challenges	Sensitive Personal Data — hashed / short-lived

Not collected: medical records, biometric data, government photocopies stored beyond the ID number field.

---

3. Data flow for a user right request

Data-subject request via the student dashboard, then a call into `physioguidance-api`, then an audit-log write, then a response.



The same shape applies to Delete Account and Consent Change — each writes to `audit_logs` before returning to the user.

---

4. User rights — implementation-by-article

4.1 Article 4 (Lawful basis) — Implemented

- All personal-data collection tied to explicit user action (signup, enrollment, payment).
- Legal basis for each field category documented in pdpl-data-classification.csv under the "Legal basis" column.
- Terms and Privacy Notice presented at signup; acceptance recorded with version + timestamp in `user_consents`.

4.2 Article 6 (Consent) — Implemented

- Signup consent captured for `terms`, `privacy`, and `sensitive_data` (mandatory when a National ID is provided). `marketing_email` is captured only when the user opts in at signup.
- Append-only ledger in `user_consents` with `consent_type`, `version`, `accepted_at`, `withdrawn_at`, `ip_address`, `user_agent`.
- Student dashboard exposes Settings then Privacy with toggles for marketing and sensitive-data consent.
- **Cookie consent** (Article 4 + cookie best practice): a bilingual EN/AR banner appears on the first visit before any third-party tracker fires. Three categories:
  - **Essential** — the session cookie that keeps the visitor signed in. Always on; cannot be disabled.
  - **Analytics** — Google Tag Manager (`GTM-P8RKDMNL`) + Google Analytics 4 (`G-Z9DZXJQCWY`). Runs only after consent.
  - **Marketing** — Meta Pixel (`1956469491660011`). Runs only after consent. Strict opt-in: nothing in the analytics or marketing categories injects until the visitor explicitly accepts. Choices persist in `localStorage` under a versioned key so any future policy change forces a fresh prompt. A "Cookie preferences" link in the site footer reopens the modal so visitors can change their choice at any time. Implementation: `frontend/src/components/cookie-consent/` + `frontend/src/lib/cookie-consent.ts`.

4.3 Article 11 (Right of Access + Rectification) — Implemented

- **Access:** `GET /auth/me` returns the current profile snapshot; `GET /me/export` returns the full portable bundle.
- **Rectification:** `PATCH /auth/profile` covers name, phone, bio, and other editable fields. National ID / Iqama is a one-time-set field — once populated it cannot be changed via the profile UI (enforced with `NATIONAL_ID_LOCKED` error).

4.4 Article 12 (Right to Erasure) — Implemented

- User-initiated at Settings then Privacy then Delete Account, with password re-authentication.

- Soft-delete on request: `deleted_at` stamped, `is_active = false`, immediate access revocation via existing auth guards.
- Confirmation email carries a signed cancel-deletion JWT (30-day validity — matches the grace window). Public `POST /me/account/cancel-deletion` restores the account when the link is used in time.
- After the 30-day grace window, hard-deletion is executed by an operator via a maintenance procedure that walks the 68 FK-referenced tables (audit written before deletion). The retention job independently purges long-inactive `STUDENT` accounts under §7.

4.5 Article 13 (Data Portability) — Implemented

- `GET /me/export` returns a machine-readable JSON bundle in the HTTP response body — no email, no signed URL, no external job.
- Includes: profile (with PII fields decrypted at export time), enrollments, certificate requests, attendance, consents, preferences, and the subset of audit-log rows the user themself performed.
- Excludes payment records (governed by the separate SAMA / ZATCA retention path), other users' PII from shared sessions, and internal system columns (password hash, refresh tokens, OTP codes).
- Rate-limited to one export per 24 hours per user, enforced server-side by looking up the last `right_to_portability_export` audit-log row.

4.6 Article 18 (Data retention) — Implemented

- Automated purge job runs daily at 02:00 UTC (see §6).
- Audit-log rows retained indefinitely as compliance evidence; IP address is anonymised (last octet zeroed for IPv4, last 64 bits dropped for IPv6) once the row is older than 90 days.
- Cloud SQL automated backups retained per the GCP-managed policy (see gcp-deployment.md); the DR-copy bucket lifecycle is set to 30 days.

4.7 Article 25 (Security) — Implemented

- All at-rest PII encrypted with AES-256-GCM via `encryptPII` / `decryptPII` in `backends/src/common/crypto.ts`.
- Passwords hashed with argon2 (memory-hard).
- TLS-only transport (Cloud Run enforces).
- Cloud SQL SSL-required + private IP + deletion protection + PITR.

4.8 Article 26 (Cross-border) — Implemented

- All data in me-central2 (Saudi Arabia). No cross-border transfer occurs.
- Third-party integrations catalogued in third-party-services-ownership.csv.

4.9 Article 27 (Breach notification) — Implemented

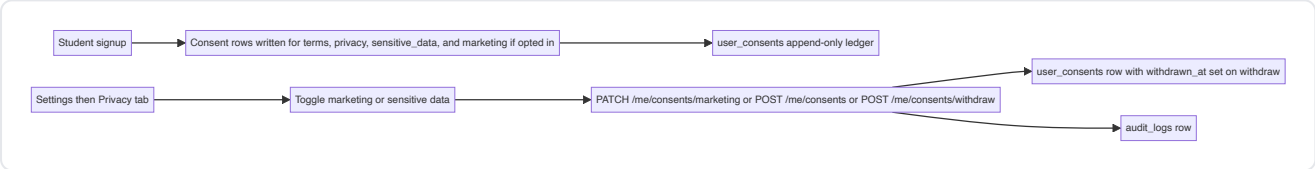
- Detection pipeline: Sentry (initialised in `backends/src/instrument.ts`, wired into the global exception filter) for application errors, Cloud Logging + uptime alerts for infrastructure signals.
- Owner receives real-time alerts — enables detection well inside the 72-hour SDAIA notification window.
- Alert routing detail in monitoring-alerting.md.

4.10 Article 29 (Data residency) — Implemented

- All data + processing in me-central2 (Dammam), driven by `GCP_REGION=me-central2` in `infra/config.sh` and applied by every deploy script.
- Full inventory + verification commands in gcp-deployment.md.

---

5. Consent management (marketing + sensitive data)



5.1 Marketing consent

- Toggle at Settings then Privacy.
- Endpoint: `PATCH /me/consents/marketing` with `{ enabled: boolean }`. `true` grants a new consent row; `false` sets `withdrawn_at` on the active row.
- Withdrawal is instant; suppresses future marketing-only emails.
- Transactional emails (receipt, certificate, password reset) are not suppressed — those run on legitimate-interest or contractual basis, not marketing consent.

5.2 Sensitive-data consent

- Toggle at Settings then Privacy.
- Grant: `POST /me/consents` with `{ type: "sensitive_data" }`. Withdraw: `POST /me/consents/withdraw` with `{ type: "sensitive_data" }`.
- Applies to processing of sensitive identifiers (National ID / Iqama, SCFHS number, refund IBAN). Consent is also captured automatically at signup when the user supplies a National ID.

5.3 Consent withdrawal audit

Every consent change writes a row to `audit_logs` with:

- `entity_type = 'user'`, `entity_id = <user id>`
- `performed_by = <user id>` (self-action)
- `action = 'pdpl.consent_withdrawn'` on withdraw, `'pdpl.consent_granted'` on grant
- `metadata` = `{ consentType, version }` on grant, `{ consentType }` on withdraw
- `ip_address` captured from the request

Admin can query: Admin then Compliance then PDPL Requests, or hit `GET /admin/pdpl/requests` directly.

---

6. Retention and purge automation

A single daily job — `RetentionService.run()`, scheduled via NestJS `@Cron('0 2 * * *')` inside the worker service — enforces every retention rule below. A Redis-backed distributed lock (`lock:cron:pdpl-retention-purge`) prevents duplicate execution when the service is scaled horizontally.

Data	Retention rule	Action
`refresh_tokens`	7 days past `expires_at`	Hard delete
`email_verifications`	30 days past `expires_at`	Hard delete
`two_factor_challenges`	7 days past `expires_at`	Hard delete
`audit_logs.ip_address`	older than 90 days	Anonymise (IPv4 last octet zeroed; IPv6 truncated to /64)
Inactive `STUDENT` users	last login older than 24 months, no active enrollments, no approved certs, no pending refund	Email a 30-day warning; stamp `inactive_warned_at`
Inactive `STUDENT` users past grace	`inactive_warned_at` older than 30 days and still inactive	Hard delete (FK cascade across 68 dependent tables, audit written first)
`audit_logs` body	never	Retained indefinitely for compliance evidence
Cloud SQL backups	GCP-managed daily + PITR window	GCP-managed lifecycle
DR-copy bucket (`physioguidance-backups`)	30 days	Bucket lifecycle rule
Cloud Logging	GCP `_Default` bucket policy	GCP-managed

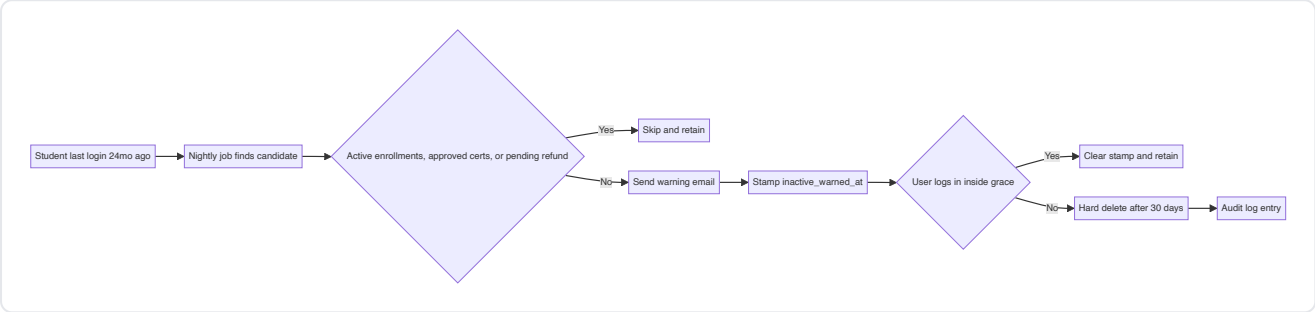
Regulatory-retention tables (`audit_logs` body, `nelc_audit_logs`, payment records, certificates) are never touched by this job — those have multi-year retention driven by NELC / ZATCA / SAMA rules and

follow their own archival flow.

---

7. Inactive-user handling

Full policy in pdpl-inactive-user-policy.md. Summary:



Key design decisions confirmed with Amna:

- Threshold: **24 months** of inactivity
- Behaviour: **notify then delete** (never silent purge)
- Exemptions: active or completed enrollments, approved certificates, pending / approved / processing refunds
- Grace period: **30 days** from warning email
- Recovery: login during grace clears `inactive_warned_at`
- Scope: `STUDENT` role only — instructors, admins, support and course managers are exempt because their roles imply ongoing operational relevance

---

8. Audit trail for privacy-related requests

Every PDPL-relevant action writes to `audit_logs`:

Action	Written by	Where visible
`pdpl.consent_granted` / `pdpl.consent_withdrawn`	User via UI (`ConsentsService`)	Admin then Compliance then PDPL Requests
`right_to_erasure_requested`	User via Delete Account (`ErasureService`)	Same
`right_to_erasure_cancelled`	User via cancel-deletion link	Same
`right_to_portability_export`	User via Export My Data (`DataExportService`)	Same
`pdpl.inactive_warned`	Retention job on behalf of the user	Admin then Audit Logs (general view)
`pdpl.inactive_deleted`	Retention job (`performed_by = system`)	Admin then Audit Logs (general view)

`GET /admin/pdpl/requests` returns a filterable, paginated view of the first four action types (closed-list vocabulary — new PDPL actions are added explicitly so nothing appears on the auditor report until documented). `GET /admin/pdpl/summary` returns counters for the dashboard tile.

---

9. PII encryption at rest

Algorithm: AES-256-GCM with a per-encryption random IV **Format:** `v1:<base64-iv>:<base64-authTag>:<base64-ciphertext>` **Key source:** `PII_ENCRYPTION_KEY` in Secret Manager, injected into every runtime that reads or writes these fields (backend, worker, migration jobs) **Version prefix:** enables future key or algorithm rotation without touching existing rows; legacy plaintext rows are read transparently

Fields encrypted:

- `users.phone`
- `users.national_id`
- `users.scfhs_number`
- `payment_receipts.refund_iban`
- `payment_receipts.refund_national_id`
- Payment-gateway API secrets (Moyasar / Tamara / Tabby) written by `payments-secrets.util.ts`

Fields hashed (not reversible):

- `password_hash` — argon2
- Password-setup and email-verification tokens — SHA-256

Fields plain (identity or lookup keys):

- Email (indexed lookup key)
- Names, bio, location (functional fields)

Rotation procedure for `PII_ENCRYPTION_KEY` in secrets-rotation-plan.md.

---

10. Data residency (Article 29)

All resources in me-central2 (Dammam, Saudi Arabia):

- Cloud SQL (Postgres 15, `physioguidance-db-me`)
- Redis (Memorystore)
- GCS buckets (regional in me-central2)
- Cloud Run services (`physioguidance-api`, `physioguidance-api-worker`, `physioguidance-web`, `physioguidance-cms`) and Cloud Run Jobs
- Secret Manager (auto-replicated within me-central2)

The region is pinned in `infra/config.sh` via `GCP_REGION="me-central2"` and every deploy script sources it. Full inventory + verification commands in gcp-deployment.md.

---

11. Controls matrix — every control classified

The full matrix is in pdpl-controls-matrix.csv. Summary of the classification distribution using Amna's four-category vocabulary:

Classification	Count	Examples
Implemented	23	User export, account deletion request + 30-day grace + cancel link, consent toggles, retention job, PII encryption at rest, breach detection pipeline (Sentry + Cloud Logging), argon2 password hashing, audit log, post-grace hard-delete via operator maintenance, cross-border residency (all in me-central2), bilingual cookie-consent banner gating GTM/GA4/Meta Pixel (strict opt-in)
Not Applicable	1	Automated Decision-Making Disclosure — no algorithmic decisions about users; grading and course assignment are instructor-driven
Requires Client/Legal Action	6	Inactive-user handling policy sign-off, Privacy Notice content finalisation, Terms of Service content, Data Controller identification, Data Breach Notification procedure, Third-Party Processor Register (DPAs with Zoom, NELC, Moyasar)

Full detail per control (control ID, description, PDPL article reference, status, evidence endpoint, notes) in the CSV.

---

12. Related deliverables

- pdpl-controls-matrix.csv — per-control status + evidence
- pdpl-data-classification.csv — fields classified by sensitivity + legal basis
- pdpl-inactive-user-policy.md — the 24-month / 30-day / notify-then-delete policy detail
- Privacy Notice drafts (EN + AR) in the `privacy-notice-draft/` folder (repo)

---

13. Where to look next

- **How each user right is exposed in the UI —** student-guide.md
- **How data is protected in transit and at rest —** security-architecture.md
- **How audit-log evidence is queried —** platform-owner-guide.md
- **Backup, DR, and regional accepted-risk —** regional-failure-playbook.md